

API SECURITY RISK ANALYSIS REPORT

Submitted By:

K.V.J.S.Varalakshmi

Internship:

Cyber Security Internship

Task:

Task 3 – API Security Risk Analysis

Tools Used:

Postman

Date:

20-07-2026

Objective:

The objective of this task is to analyze a public API using Postman, identify potential security risks such as authentication, authorization, data exposure, and rate limiting issues, and provide recommendations to improve API security.

Tools Used:

- Postman
- Sample Public API
- Microsoft Word
- GitHub

API Details:

API Name: JSONPlaceholder

Endpoint:

<https://jsonplaceholder.typicode.com/users>

Method:GET

Testing Procedure:

- Opened Postman.
- Created a GET request.
- Entered the API URL.
- Sent the request.
- Observed the JSON response.
- Checked the Authorization tab.
- Checked the Request Headers.
- Checked the Response Headers.

Security Risks:

Risk	Observation	Recommendation
Authentication	No Auth used	Use JWT/API key
Authorization	No access control visible	Implement Role-Based Access control
Data Exposure	User details are returned	Return only required data
Rate Limiting	Rate-limit headers present	Continue using rate limiting
Input Validation	Cannot be verified	Validate all user input

Business Impact:

- Unauthorized users may access public endpoints.
- Sensitive information could be exposed if the API contains private data.
- Lack of proper authorization may allow unauthorized access.
- Weak input validation can increase security risks.

Recommendations:

- Use JWT or API Keys.
- Implement Role-Based Access Control.
- Validate all user inputs.
- Limit sensitive data exposure.
- Continue using rate limiting.
- Monitor API activity and logs.

Screenshots:

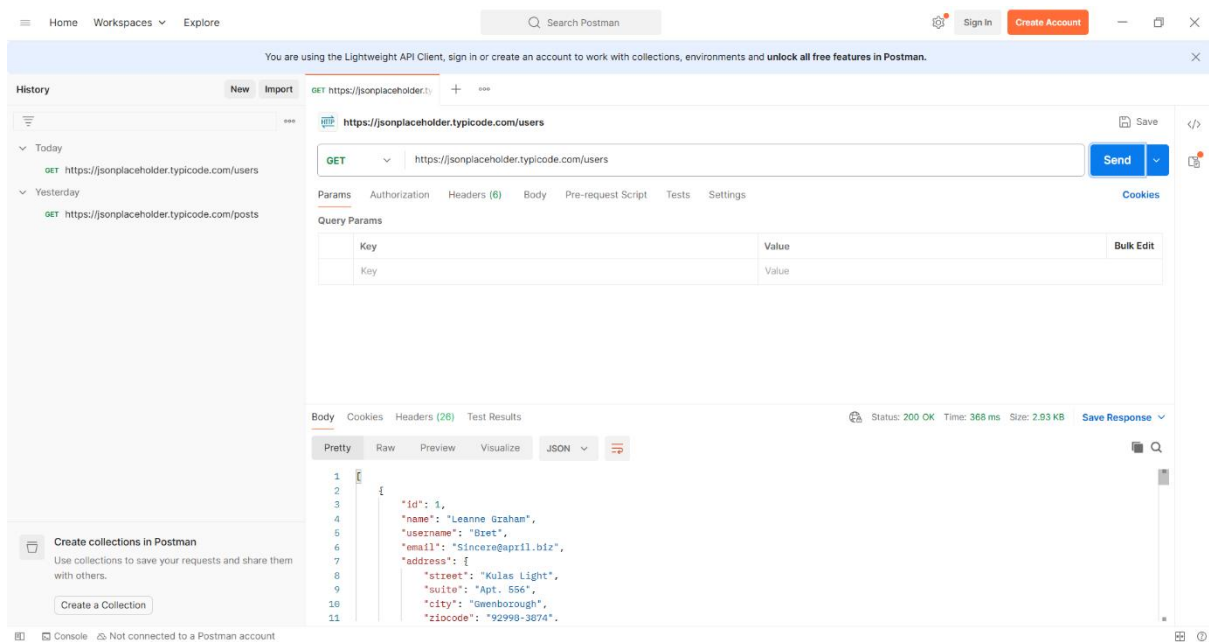


Figure 1: GET Request and Response

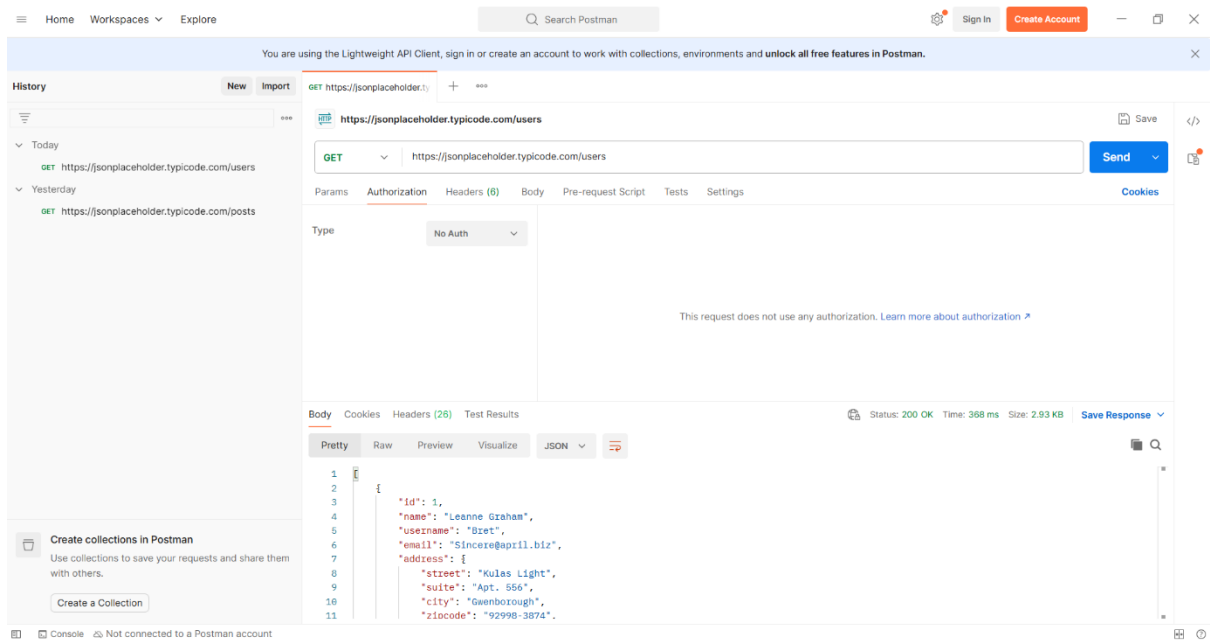


Figure 2: Authorization – No Auth

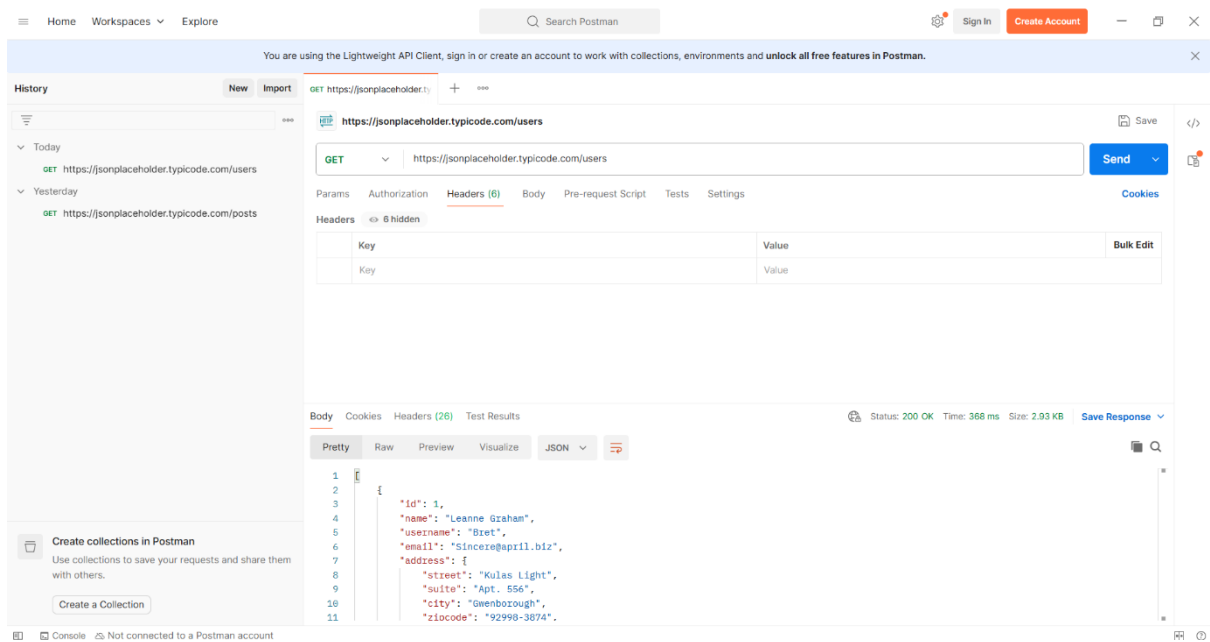


Figure 3: Request Headers

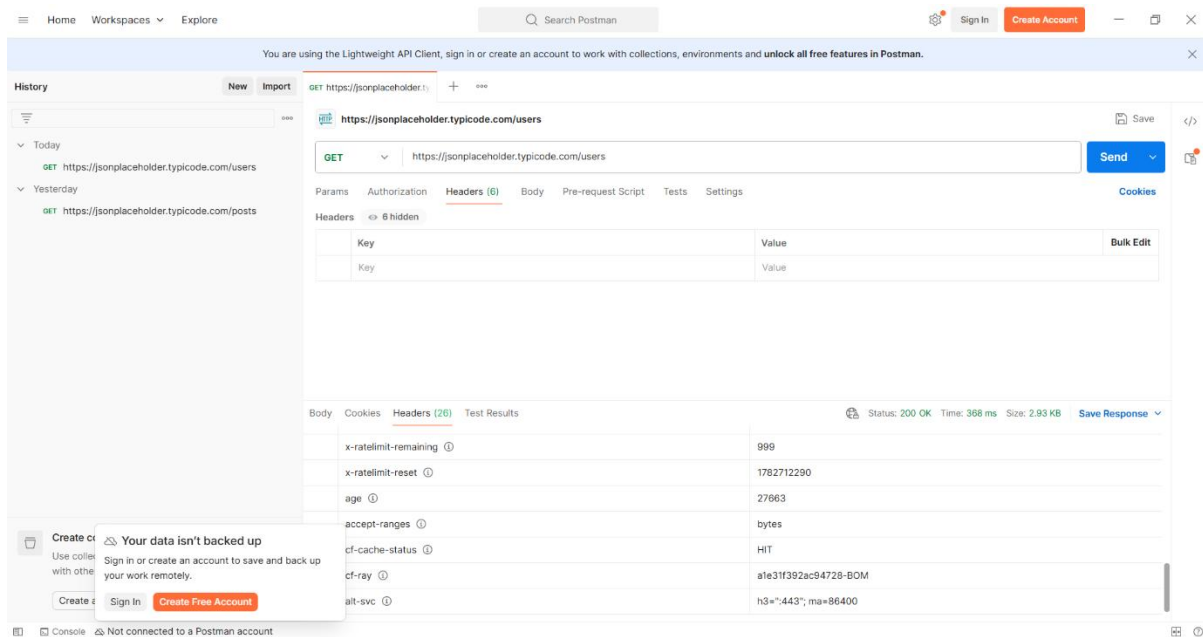


Figure 4: Response Headers

Conclusion:

The API Security Risk Analysis was successfully completed using Postman. The public API responded correctly and demonstrated a publicly accessible endpoint. While this is acceptable for a demo API, production APIs should implement authentication, authorization, input validation, rate limiting, and continuous monitoring to protect sensitive data and improve overall security.